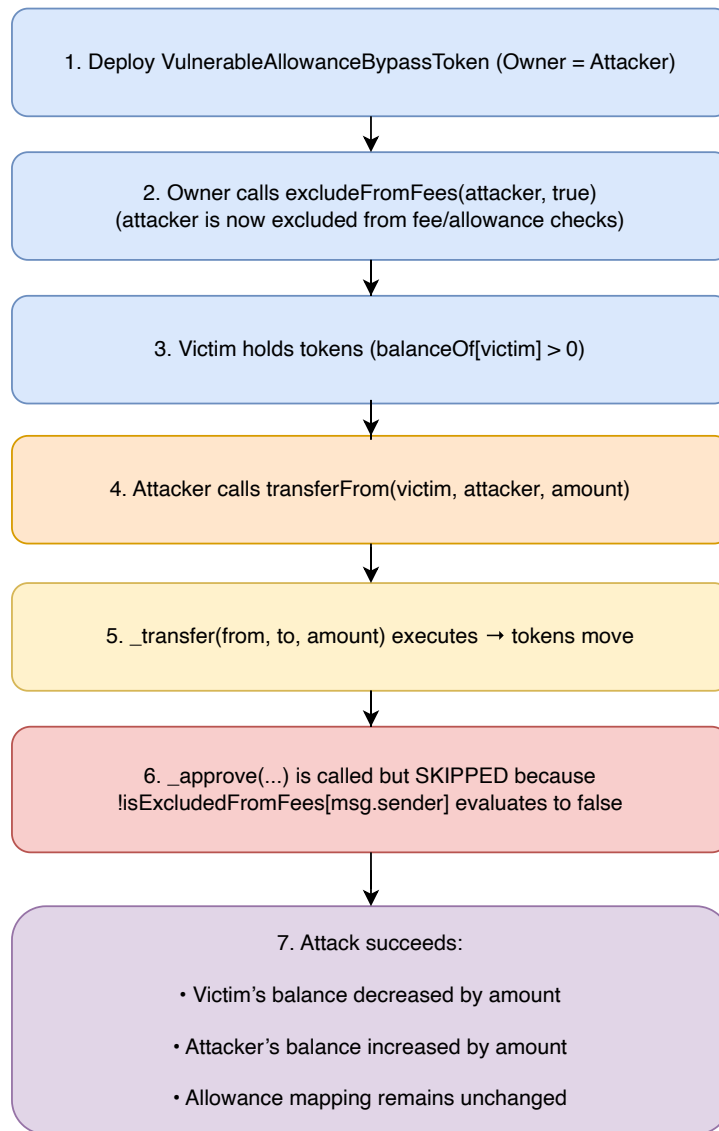


Approval Risk Exploit – VulnerableAllowanceBypassToken



Why the attack works

Root Cause:

The allowance check is placed *after* the transfer and is conditionally executed only if the caller is NOT excluded from fees. If the caller is excluded, the deduction is skipped entirely, allowing unrestricted transfers from any user without checking or reducing allowance.

Recommendation:

Always validate allowance before transferring (or at least ensure the check is unconditional). A flexible fee-exclusion mechanism must never interfere with core access control logic.

Observed Proof in the Demo

- Attacker (excluded) successfully calls `transferFrom()` on victim
- Transfer event emitted with correct amounts
- Victim's allowance for attacker remains zero or unchanged (no Approval event)
- State: victim's balance reduced, attacker's increased – all without valid allowance